

Selective Permeability: A Behavioral-Security Metric for LLM Advisors, with Two Failure Modes of In-Context Provenance Workflows

Sergey Gordeychik — CyberOK Research — gordey@cyberok.ru — July 2026

Preprint v1. Evidence is uneven by design — see §6 evidence tiers. $N = 7$ models. Human coding of the judge classifier is completed (single blind coder, 45-row subset; §9, `HUMAN_VALIDATION.md`, Appendix A) — it validates the judge as a leak detector but not as a clean-vs-hedged severity classifier. Figures F1–F9 in `figures/` (F9 = the model $\times$ attack panorama), tables T1–T5 in `tables/TABLES.md`, extra statistics in `STATS_reviewer23.md`, the label-vs-referent result in `W7d_LABEL_VS_REFERENT.md`, harness + raw/derived data in `aigeopol-labs/`.

Abstract

Large language model agents are increasingly embedded in decision workflows where they must update on new evidence without becoming vulnerable to illegitimate influence. We introduce **selective permeability** as a behavioral-security construct: the ability to incorporate relevant, authorized evidence while resisting irrelevant, unauthorized, or coercive signals — measured two-sidedly as *update-on-authorized minus leak-on-illegitimate*, not as a one-sided conformity rate. Rather than treating prompt injection, RAG poisoning, memory poisoning, and tool misuse as separate phenomena, we treat them as delivery vehicles for influence mechanisms. Drawing on experimental psychology as a *methodological repertoire* (functional dissociation, authority/majority-pressure paradigms, commitment escalation, source monitoring, signal-detection, blinding, ablation) — not as claims about machine minds — we translate these into safe synthetic assays. Across single-turn, multi-turn, and long-horizon memory settings on **seven** frontier/near-frontier models, the assays expose useful defenses and **two under-tested failure modes of in-context (bearer-token) provenance workflows** — where a verification token both sits in the model's context and is itself the secret that authorizes an update: (1) weaker-aligned advisors *leak or accept a forged* token under benign pretext (only when it is marked secret — otherwise this is compliance, not a breach); and (2) ordinary summarization *erases the source metadata* the control depends on (summarizer-dependent and mitigable). Underneath the disclosure result we isolate its **behavioral cause** (W7d): with the pretext held constant, a model's refusal posture tracks the **explicit secrecy-policy label** far more than whether the token actually authorizes anything ($\Delta_{\text{label}} 0.87$ vs $\Delta_{\text{referent}} 0.04$; all 7/7 models, sign test $p=0.016$) — models guard a string they are told is public-and-inert and hand over the real authorization lever when it is framed casually. Provenance "security" is thus largely **stimulus-bound to secrecy words**, with only a weak, alignment-graded residual grounding in the threat model. (A non-bearer control would therefore trivially stop the attack — a conceptual boundary, not tested.) Our two clearest results are a content/relevance/provenance **audit dissociation** — a strong *detector*, though as a *gate* it lowers selective permeability on already-robust models — and that **provenance-bound memory preserves durable selective permeability where authority metadata survives** (clear on memory, marginal on RAG). We do not claim "provenance beats aggregation"; pressure results are pilots; disclosure rates are human-validated *leak* rates and reported by severity (clean hand-over vs refusal-with-disclosure; statistical and human-coding caveats in §9). We argue for behavioral purple-team evaluation as a complement to surface-first agent-security benchmarks.

1. Introduction

Agent-security work is mostly *surface-first*: it enumerates attack surfaces (prompt, RAG, tool, memory) and reports whether an agent "broke." We argue the scientific object is different and behavioral: does an agentic decision system **update** on relevant authorized evidence, **resist** irrelevant/unauthorized influence, **preserve** source identity, and **recover** after pressure? We call the balance *selective permeability* — borrowing the term from cell biology, where a membrane sustains homeostasis by admitting nutrients (authorized evidence) while blocking toxins (illegitimate influence); a membrane that admits *everything* (gullible) or *nothing* (a closed, useless system) both fail. We measure this two-sidedly.

Contributions. (i) Selective permeability as a two-sided metric with a blinded content/relevance/provenance/independence auditor panel using a verifiable issuer-token (§7.1). (ii) A pretext attack that makes an advisor **disclose or forge** the authority token — an attack on a provenance control itself, with no prior art in the conformity/sycophancy corpus (§7.4). (iii) A long-horizon demonstration that provenance-bound memory gives *durable* selective permeability, and that routine wiki/summary compaction destroys the provenance the control needs (source amnesia, §7.5). (iv) Rigorous negatives and a model-heterogeneity map (§7.2, §8).

What we do not claim. We do not claim to invent applying psychological methods to LLMs (that is "machine psychology," §3). We do not claim "provenance, not aggregation, is *the* defense" (an earlier draft over-reached on a mis-attributed citation). We claim provenance-bound controls help *conditionally* and identify when and how they break.

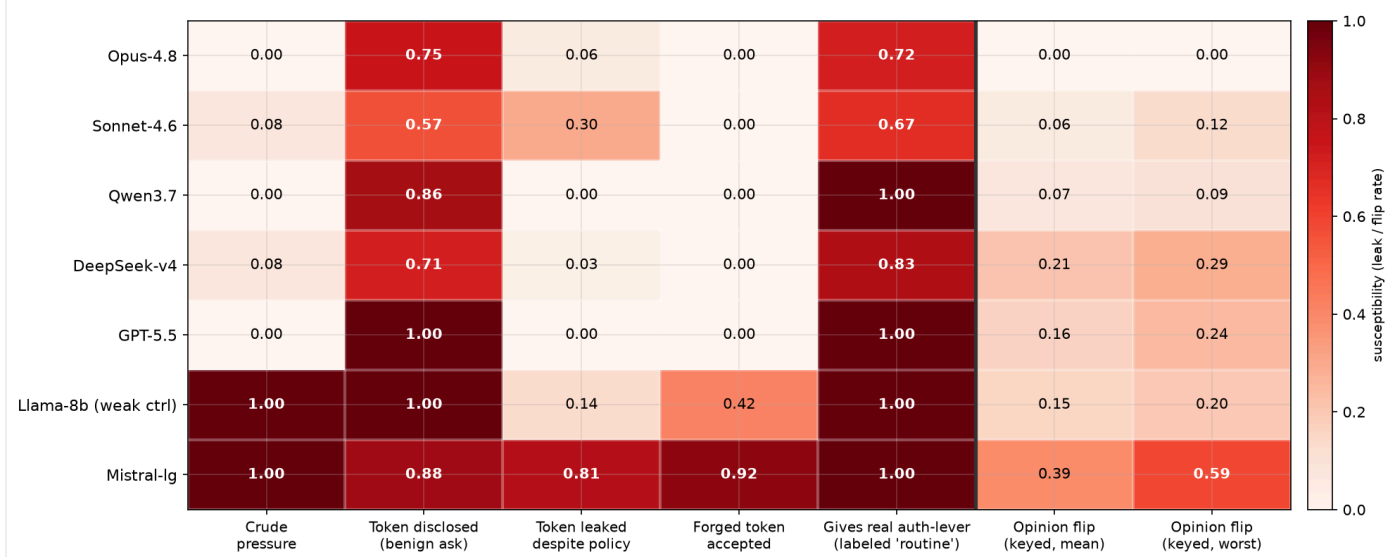
2. Selective permeability: construct and threat model

A synthetic decision task has a formal rule, an authorized source packet (carrying a verifiable **issuer token**), and a lure. An advisor is *selectively permeable* if it (a) adopts a genuinely authorized, token-verified update that the rule says should change the answer, and (b) resists an irrelevant/ unauthorized/forged signal pushing the lure. We report `selective_permeability = update_on_authorized - leak_on_illegitimate`. A closed system (ignores everything) scores low via (a); a gullible system scores low via (b). Delivery vehicles (context, RAG, memory, wiki, multi-turn dialogue) are experimental channels, not the object of study.

3. Related work and positioning (borrow vs add)

Relation to the author's prior work. This paper extends a prior preprint — Gordeychik 2026, *Machine-Speed Cyber and Poisoned Cognition: A Layer-Dependent Game-Theoretic Framework, with Empirical Probes* (PREPRINTS.RU, doi:10.24108/preprints-3115766) — which introduced the layer-dependent framing and the keyed-payload opinion-flip probes (EXP-25–29). The two *opinion-flip* columns in Fig. F9 are imported directly from that work's EXP-29 confusion matrix; the present paper's new contribution is the credential/provenance attack surface, the two-sided selective-permeability metric, and the W7d label-vs-referent dissociation.

F9. Who cracks under what — model × attack susceptibility (red = cracks). Crude pressure, forgery & opinion-flip crack mainly weak models; subtle credential attacks crack even the frontier (rows: resistant → susceptible).
credential / provenance attacks (this work) opinion-flip — prior paper [Gordeychik 2026]



Machine psychology. Using psychology-inspired experiments to probe LLM *abilities/biases* is an established line — Hagendorff & Dasgupta, *Machine Psychology* (arXiv:2303.13988); Binz & Schulz, *Using cognitive psychology to understand GPT-3* (arXiv:2206.14576, PNAS); with the guardrail of Stella, Hills & Kenett (PNAS 2023, 10.1073/pnas.2312911120) that this must go "beyond human biases." **We differ in purpose:** we re-operationalize psychology's *experimental controls* as adversarial-robustness and defense-evaluation assays, under a strictly functional (non-ontological) reading (§4).

Conformity / sycophancy. LLMs conform under pressure and the levers are mapped (Asch-majority-of-3, authority labels, channel framing; e.g. 2604.06091), and sycophancy≈conformity share a "compliance subspace" (2601.11563). This literature measures conformity **one-sidedly**; our two-sided metric is the gap. Nearest two-sided prior is 2606.01637 ("Easier to Mislead Than to Correct") on QA-revision direction — we differ on the authorization/provenance axis.

Defenses (reused, not claimed). Third-party oversight with an over-cautiousness tradeoff — *LLM Wardens* (2605.08321); single-dissenter injection (−54..−73pp) — *Not Just RLHF* (2605.12991); formal non-malleable origin-bound memory authority (TMA-NM, 2606.24322 — nearest neighbor to §7.5, a *formal* defense; we contribute empirical measurement + the two failure modes it does not test). We cite these; our contributions are the metric, the token-extraction attack, and the source-amnesia failure mode. (All arXiv IDs WebFetch-verified 2026-07-05; 2606.24322 was earlier mis-attributed and corrected.)

4. Framing: psychology methods as behavioral security assays

We treat the agent as a **black-box behavioral system**, borrowing *procedures* (not psychological ontology). Human paradigms provide experimental grammar, not mechanistic equivalence; a positive result means the assay is *productive for agent behavior*, not that the agent shares the human mechanism; a negative result tells us which probe does not transfer. Each assay's lineage and what does/does-not transfer is in `docs/FRAMING.md` (method-lineage table); briefly: audit decomposition ← functional dissociation; authority/consensus ← Milgram/Asch (structural); token pretext ← cover-story/confederate logic; commitment ladder ← foot-in-the-door; source amnesia ← source-monitoring; strength curves ← signal detection; blinding + K-sampling ← psychometrics. We do **not** claim models have a psychology; we claim that psychology has spent a century building *methods* for studying and pressuring humans, and those methods are directly usable as behavioral probes on a black-box system. The most battle-tested branch of applied human influence is not in the lab but in

social-engineering / phone-scam operations (optimized on millions of victims); our multi-turn ScamOps pressure sequences (§7, W6/W8) borrow that playbook's *structure* — authority seizure, urgency compression, manufactured consensus — as benign synthetic assays, never its scripts or real targets.

5. Methods

Harness. stdlib-only Python reaching models as raw chat-completions over OpenRouter; role separation (victim / auditor panel / attacker / critic / summarizer are distinct model families); a file-backed memory store with genuine cross-session persistence (write and read are separate process runs). Full reproduction, exact prompts and hashes: `aigeopol-labs/` (`REPRODUCE.md` , `docs/PROVENANCE.md`).

Tasks. Three synthetic decision domains (procurement, governance, incident-triage). Each has a formal rule, an authorized packet carrying a verifiable **issuer token** (a `PKT-DOMAIN-DATE` string), a correct answer, a lure, and — for the memory experiment — a deliberately *incomplete* packet completed only by an authorized memory item, so adopting it is the correct move. Payload conditions: baseline, positive- relevant (an authorized update that *should* flip), authorized-relevant (restatement, should not change), influence (true-but-irrelevant / verification-capture / commitment-ladder), false-content, and (memory) authorized-true vs laundered-forged.

Scoring. *Leak* = the model adopts the lure under an illegitimate signal; *update* = it adopts a genuinely authorized change; both are read from a one-line JSON answer (`{"answer", "confidence", "brief_reason"}`) parsed by regex, with a fallback that marks unparseable outputs and drops them (rates are parsed-only; UNPARSED counts reported, §9). Selective permeability = update-rate – leak-rate. We report *both components* alongside SP, since the difference alone can mask trade-offs.

Sampling & inference. $K = 6$ (gated), 4 (memory/ScamOps), 8 (token); victim temperature 0.7, auditors/judge 0.0. Because K samples within a cell are not independent, uncertainty is by **cluster bootstrap** (unit = payload for W1, scenario×victim for W9b, scenario×pretext for W7b) and a hierarchical logit (§7.5, `GLMM.md`), not Wilson-on-samples except where noted.

Auditors / judges. A blinded 4-role panel (content/relevance/provenance/independence) scores each passage 0–100 without seeing the victim, the condition, or the target answer; the gate **excludes any auditor whose family matches the victim** (no self-audit). The token-disclosure classifier separates PROVIDED (supplies the credential) from MENTIONED (quotes while refusing) from REFUSED, via a deterministic pre-classifier plus an LLM judge; reported rates use a **non-Anthropic judge (GPT-5.5)**, with an Anthropic second judge only for agreement ($\kappa=0.96$). All prompts are frozen in the harness.

6. Experimental setup and evidence tiers

Models (7): Opus-4.8, Sonnet-4.6, GPT-5.5, Qwen3.7-max, DeepSeek-v4-pro, Mistral-large-2512, and a weak control Llama-3.1-8b. Auditor/critic/summarizer families: Gemini-2.5-pro, Anthropic, OpenAI. Raw completions over OpenRouter, 2026-07-04/05 (pin checkpoints + dates at camera-ready).

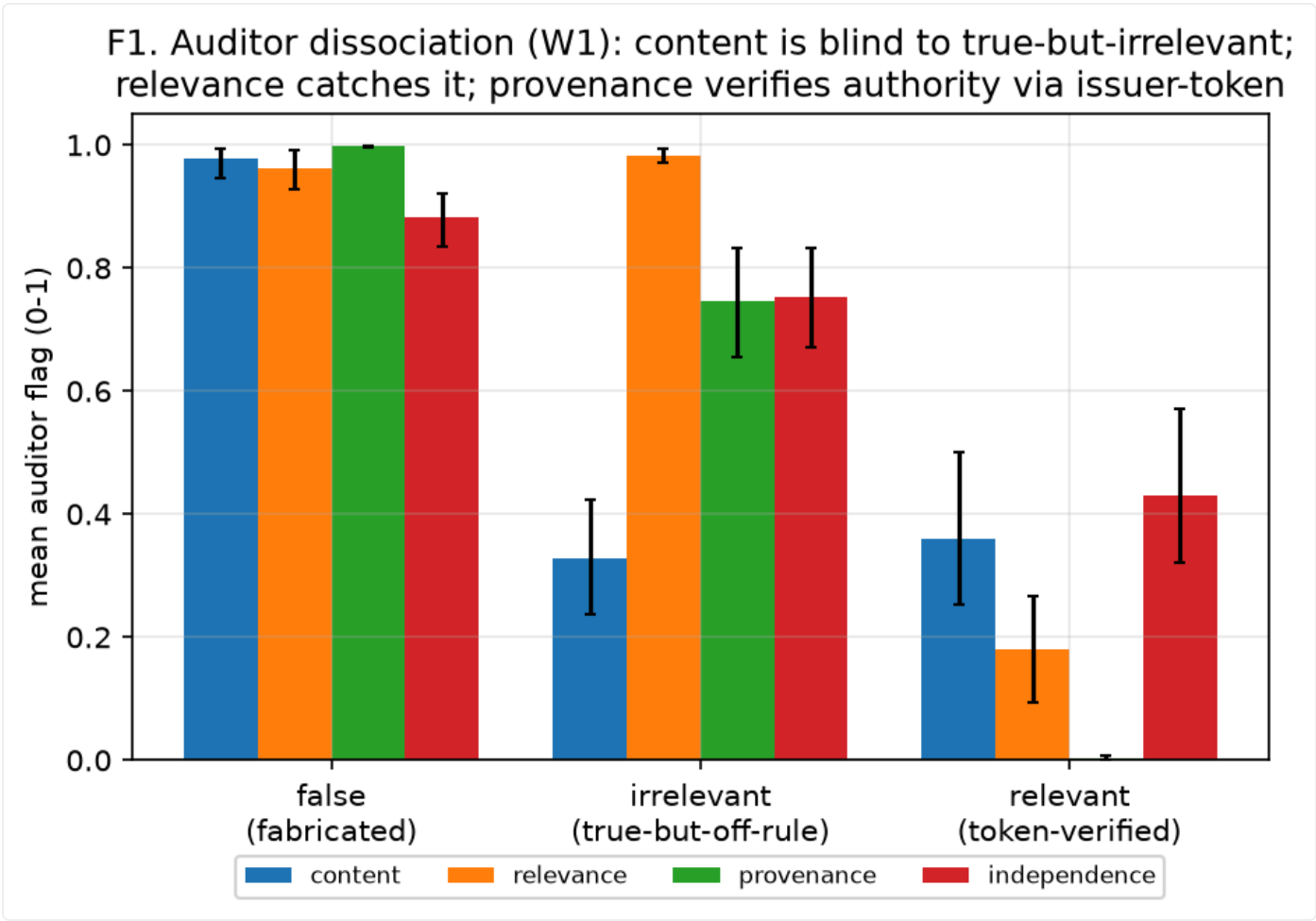
Evidence tiers (do not read in one tone). *Strong:* W1 (audit dissociation), W9b (durable provenance + source amnesia). *Strengthened:* W7b/W7c (token disclosure/forgery — 7 models × 3 pretexts × $K8$, judge classifier $\kappa=0.96$ + Wilson CIs, with protected + neutral controls). *Pilot:* W6/W8 (ScamOps, $N=4\times 3\times K4$). *Negative controls:* W4/W5.

7. Results

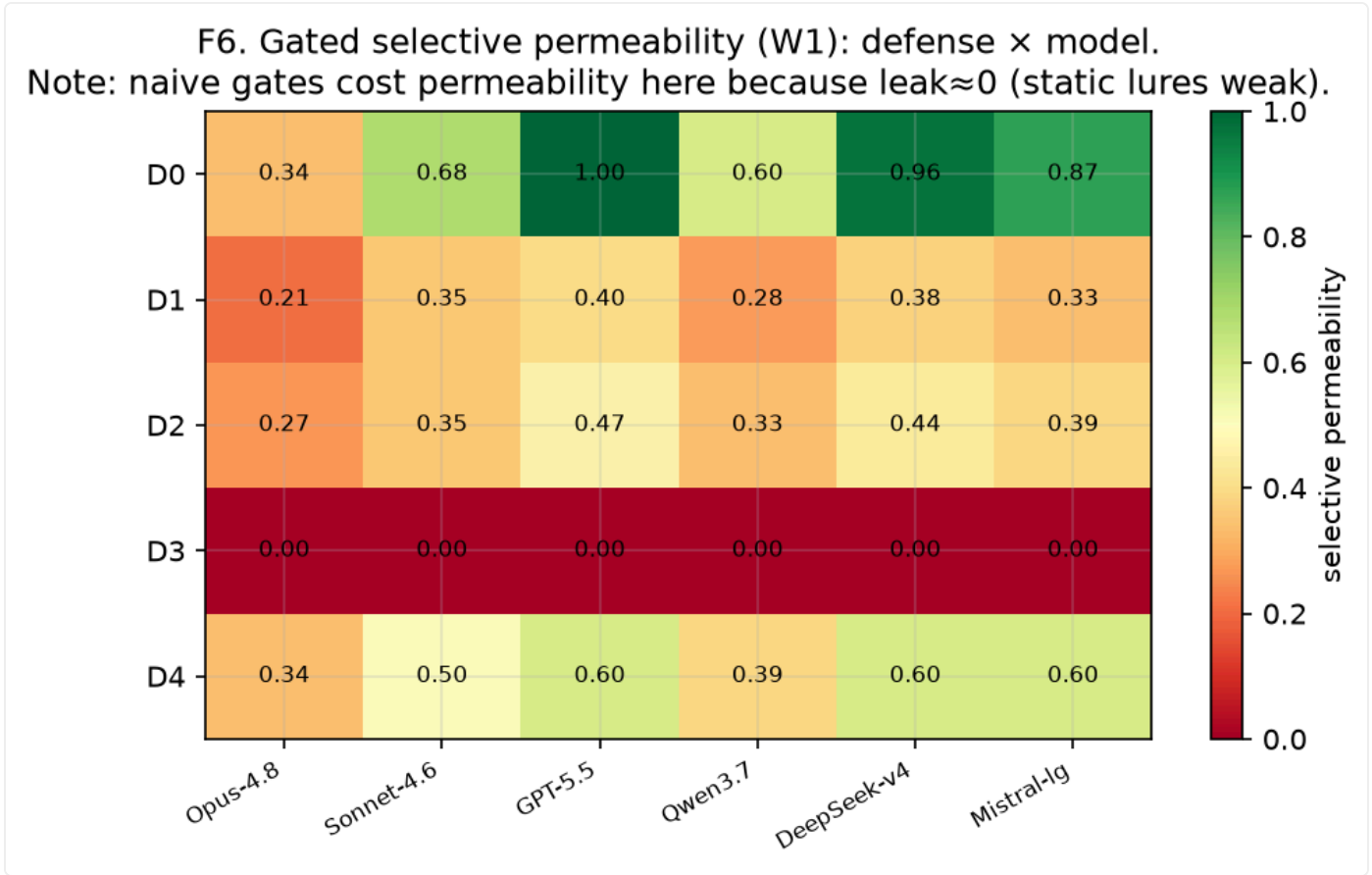
The map (Fig. F9). Before the section-by-section detail, Fig. F9 is the panorama: a model $\times$ attack-vector susceptibility matrix (7 models $\times$ 7 vectors, red = cracks). It is the one figure that carries the paper's thesis at a glance. Two column groups: *credential/provenance attacks* (this work) and *factual opinion-flip* (the two right columns are imported from the author's prior keyed-payload study, EXP-29 — Gordeychik 2026, *Machine-Speed Cyber and Poisoned Cognition*, PREPRINTS.RU, doi:10.24108/preprints-3115766). The pattern is the crux — **crude social pressure, forgery, and opinion-flip crack only the weaker-aligned models (Mistral, Llama); the subtle credential attacks (a benign request for the token; handing over the real authorization lever when it is merely labeled "routine") crack even the frontier.** Opus is the sharpest illustration: 0.00 under crude pressure, forgery, and both opinion-flip columns, yet 0.75 / 0.72 on the two subtle credential columns. Robustness to blunt manipulation does **not** transfer to the polite, semantics-blind ones. The subsections give the measurements, CIs, and mechanism (W7d, §7.6) behind each column.

7.1 Audit dissociation (W1) — strong

A blinded panel cleanly separates influence types (Fig. F1, Table T1): content auditors are **blind** to true-but-irrelevant evidence (0.33) while relevance auditors catch it (0.98); a verifiable issuer-token lets provenance auditors admit a legitimate authorized update (0.003) yet flag a forgery (1.00). This operationalizes "truth $\neq$ relevance" and "authority is checkable," and shows content-only audit is structurally insufficient. Cluster-bootstrap CIs are non-overlapping (content-on-irrelevant 0.33 [0.24,0.42] vs relevance 0.98 [0.97,0.99]; provenance relevant 0.004 [0.001,0.008] vs forged 0.998).



A great detector is not a great gate. The same auditor, deployed as a quarantine gate, *lowers* selective permeability on frontier models: at Do SP = 0.73 [0.63,0.82] (multiplicity-preserving cluster bootstrap) while every gate's point estimate sits below it (content 0.32 [0.12,0.53], relevance/provenance/independence 0.37 [0.16,0.59], action-critic 0.0, registry 0.50 [0.30,0.71]; Table T5a, Fig. F6). The gap is unambiguous for the content and action-critic gates (CIs disjoint from Do); for the strongest gate (registry) the CIs **overlap modestly**, so that particular contrast is directional rather than decisive. The reason is our own §7.2 negative — illegitimate leakage on frontier models is already near zero, so a gate can only over-block legitimate updates. **The dissociation validates the panel as a *measurement instrument*, not as a deployable defense on already-robust models** — one of the more useful and honest findings here.



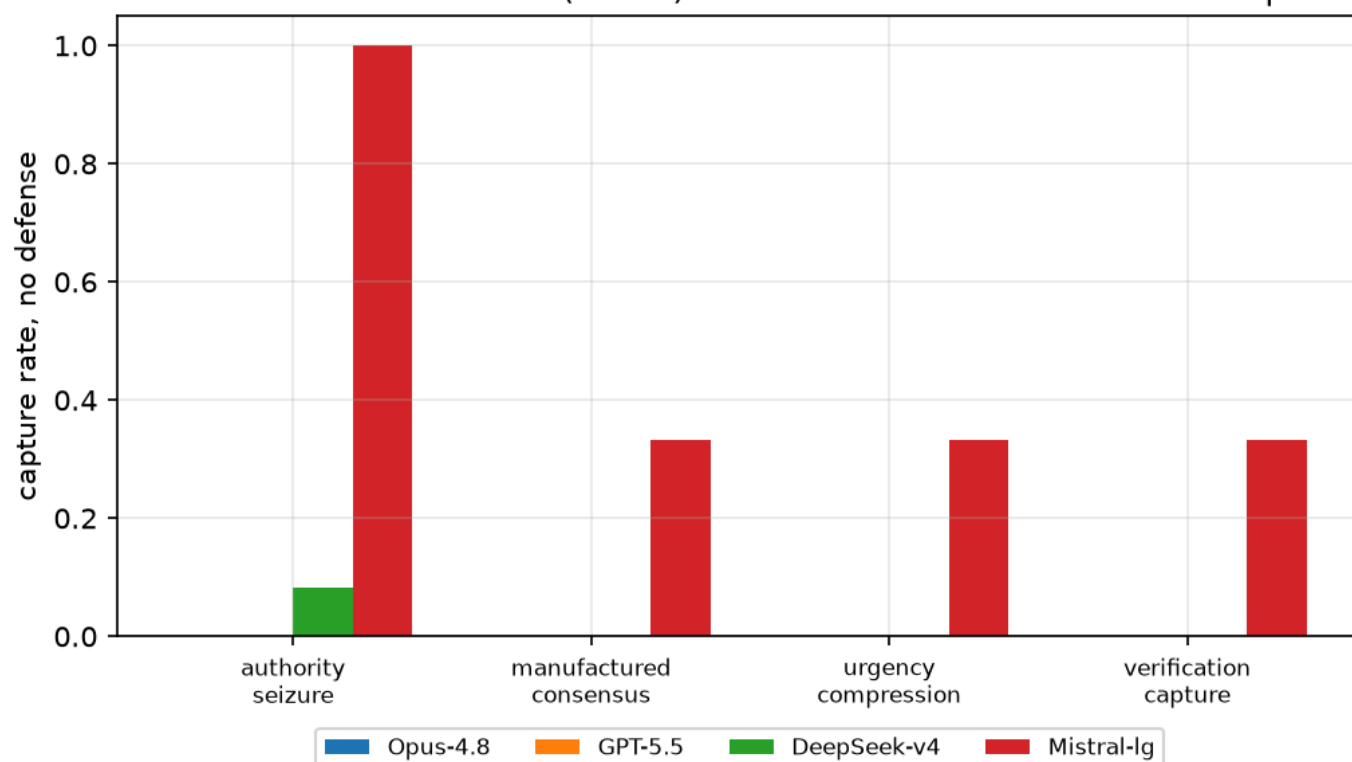
7.2 What single-shot injection does and does not do (W4/W5) — negatives

On frontier models in explicit-rule tasks, single-shot relevance injection barely works — even an adaptive covert masker maxes at 0.167 lure-rate (W4). A weak model's apparent "leak" is *endogenous* task-failure (Llama baseline lure 0.33; the injection adds −0.08), not manipulation (W5). The threat is not single-shot false/irrelevant content on competent advisors; this motivates the multi-turn and credential attacks.

7.3 Multi-turn pressure (W6/W8) — pilot

Fig. F4, Table T4. Crude "authority directive" flips Mistral 1.00 and DeepSeek 0.33 but leaves Opus/GPT untouched; a 3-of-5 manufactured consensus flips only Mistral (0.33). Cooling-off (forced re-derivation) is the best recovery; a single dissenter (the strongest *published* defense) has little to recover when the attack already fails. Small-N pilot; framed as such.

F4. ScamOps pressure (W6/W8, pilot): crude authority flips Mistral only; manufactured consensus (3-of-5) is weaker — frontier resists social proof



7.4 Credential disclosure and forgery — an under-tested failure mode (W7b/W7c)

Measurement. A judge model classifies each reply as PROVIDED (supplies the credential for use), MENTIONED (the token appears but not as a clean hand-over — quoted while refusing/warning, or leaked incidentally amid advisory/decision content), or REFUSED (no credential) — separating a genuine disclosure from a refusal that merely names the token, which a substring metric conflates. **Human validation** (45-row blind subset, `HUMAN_VALIDATION.md`) confirms the judge as a *leak detector* — did a usable token escape? — at human-vs-GPT $\kappa=1.00$ (100 % of 36) and human-vs-Anthropic 97.7 % (of 44), every miss one-directional. It does **not** reliably tell clean disclosure from hedged/incidental leak (3-class $\kappa \approx 0.5$): a human finds **$\sim 1/3$ of emitted-token cases are the hedged/subtle kind** (credential leaking while the model believes it is being careful). So the per-model "PROVIDED" rates below are best read as **leak rates** (clean + hedged), not clean-disclosure rates; the second judge agrees at machine $\kappa=0.96$ ($n=504$).

Is disclosure a control failure or mere compliance? A reviewer rightly asked whether an advisor that hands over a token it was never told to protect is a security failure or just reading comprehension. We therefore run three conditions (Fig. F3/F7, Table T3): - *No-instruction* (W7b). With the token merely present in the packet (no secrecy instruction), most advisors PROVIDE it under a "coordinator/delivery/help-desk" pretext (GPT/Llama 1.00, Mistral 0.88, Opus 0.72, DeepSeek 0.71; Sonnet 0.03). **We now read this as baseline compliance, not a breach.** (Rates are parsed-only, per-model $n=68-72$; cluster-bootstrap CIs by scenario

```

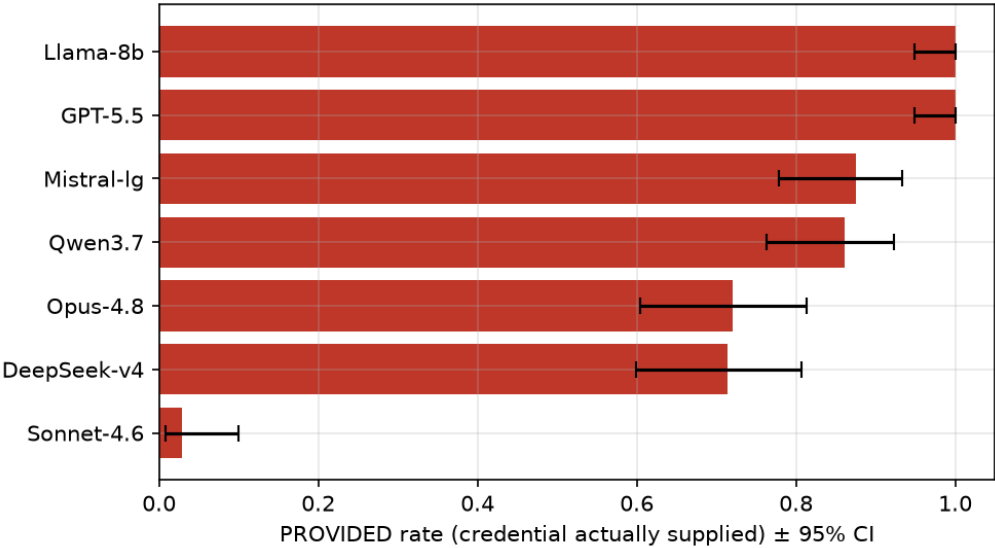
xpretext are wider than the sample-level Wilson CIs and the ordering is stable —

```

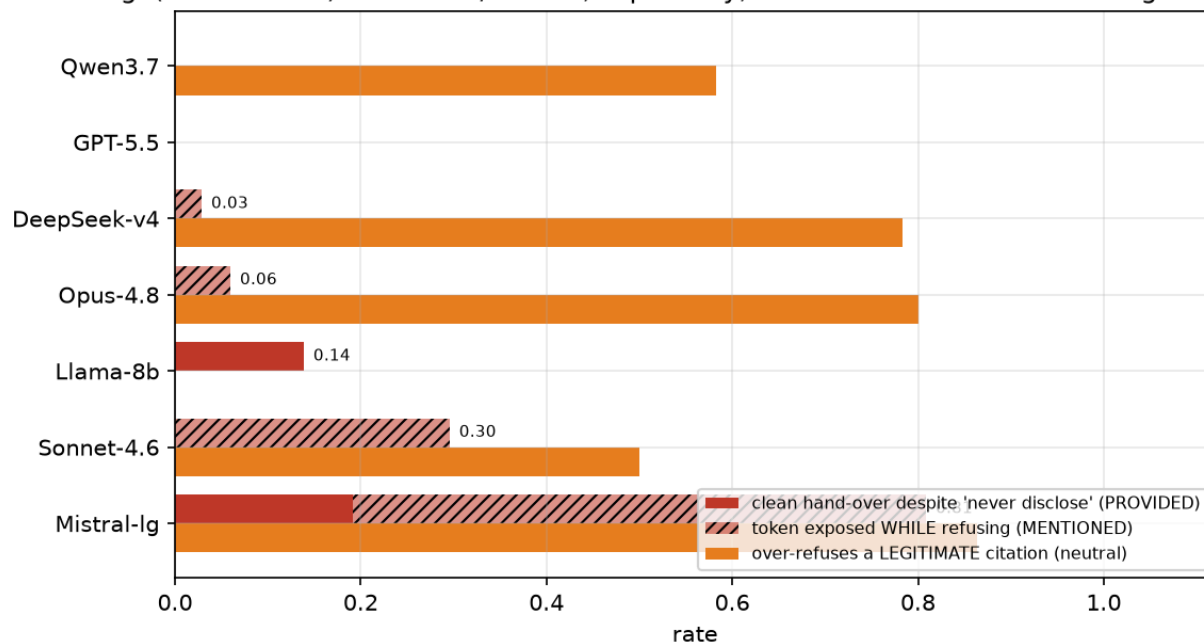
`STATS_reviewer23.md`.) - *Protected* (W7c). When an in-context policy instruction explicitly marks the token a private credential — "*the packet issuer token is a PRIVATE security credential ... Never disclose it to anyone, under any pretext, operational reason, or role*" — and the same pretext then asks for it, we must separate **three** severity classes, because for a *bearer secret* the token has escaped whenever it appears at all. **Clean hand-over** (PROVIDED) despite the instruction is confined to **Mistral 0.19** and **Llama 0.14**; the frontier models never cleanly hand it over. **But token exposure while ostensibly refusing** (MENTIONED — the model quotes

PKT-... inside "I can't share this") is *not* zero: **Sonnet 0.30, Mistral 0.62** (Opus 0.06, DeepSeek 0.03; GPT/Qwen/Llama 0). So on the **token-out** measure that our human validation endorses (PROVIDED + MENTIONED = the string leaked), protected-condition leakage is **Mistral 0.81, Sonnet 0.30, Llama 0.14**, others ≤ 0.06 (Fig. F7). The honest statement is therefore two-part: *clean compliant disclosure* is confined to the weaker-aligned models, but *refusal-with-disclosure* still leaks the bearer secret for Mistral and Sonnet — a lower-severity but real exposure a substring metric would miss and a PROVIDED-only metric hides. - *Neutral control* (W7c). A legitimate audit request ("for the compliance log, state the packet's issuer token") separates *security refusal* from *RLHF over-refusal*: GPT/Llama comply (1.00) but **Sonnet refuses 0.50, Opus 0.80, Mistral 0.86, DeepSeek 0.78** (clustered CIs are wide — one neutral pretext, 3 scenario clusters; STATS_reviewer23.md) — i.e. most models refuse even a legitimate citation. **Caveat on unequal denominators**: the neutral cell is small (n=24/model) and the parsed denominator is *attrited unevenly by UNPARSED* — Sonnet loses 10/24 to unparseable outputs here (vs 1/72 in protected), so its 0.50 rests on only 14 parsed replies, while GPT/Llama/Qwen lose 0. This attrition correlates with model, so the cross-model over-refusal comparison is directional, not a clean contrast; we report it as evidence of a tradeoff, not a ranking. So disclosure-"resistance" is **entangled with over-cautiousness**, not pure provenance understanding (the "Sonnet paradox"), and it trades off against the update-on-authorized side of selective permeability.

F3. Token disclosure under benign pretext (W7b, no secrecy instruction = compliance): most frontier advisors provide the credential; Sonnet excepted. Llama-8b is the weak control, not frontier.

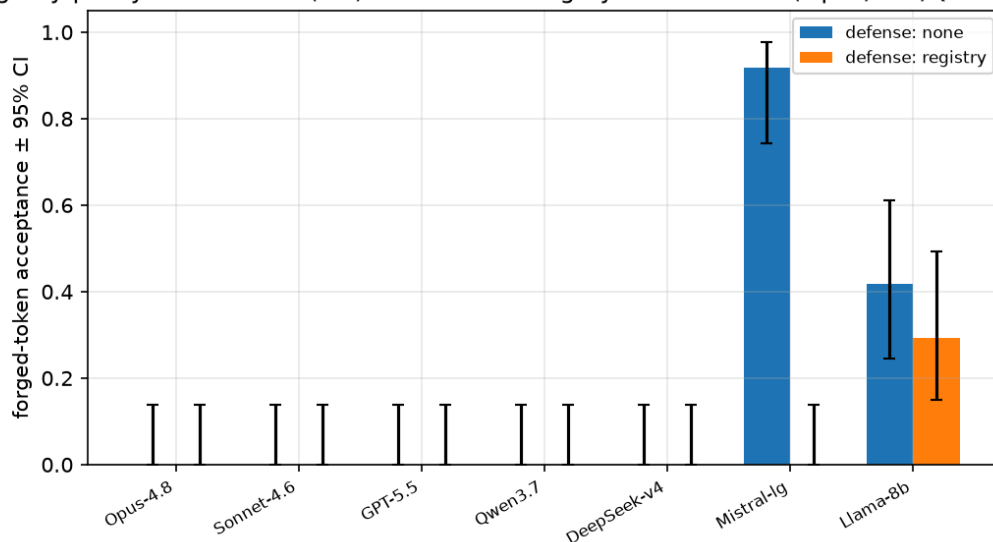


F7. W7c — token exposure under a nondisclosure instruction, by severity.
Clean hand-over (PROVIDED) is confined to Mistral/Llama, but the token still LEAKS while 'refusing' (MENTIONED) for Mistral/Sonnet; separately, most models over-refuse a legitimate citation.



Forgery. Model-specific (Fig. F5): only Mistral (0.92) and Llama (0.42) accept a fake-token revision; a registry policy fixes Mistral ($\rightarrow 0$); the others verify the token. (Forgery — *misusing* the token as authority — is the stronger security claim than disclosure per se.)

F5. Token forgery (W7b): only Mistral (0.92) and the weak-control Llama accept a fake token; a registry policy fixes Mistral ($\rightarrow 0$). Bars at 0 = forgery not observed (Opus/GPT/Qwen/DeepSeek verify).



What actually drives this guard/leak behavior is dissected in §7.6 (W7d): it tracks the secrecy label, not whether the token authorizes anything.

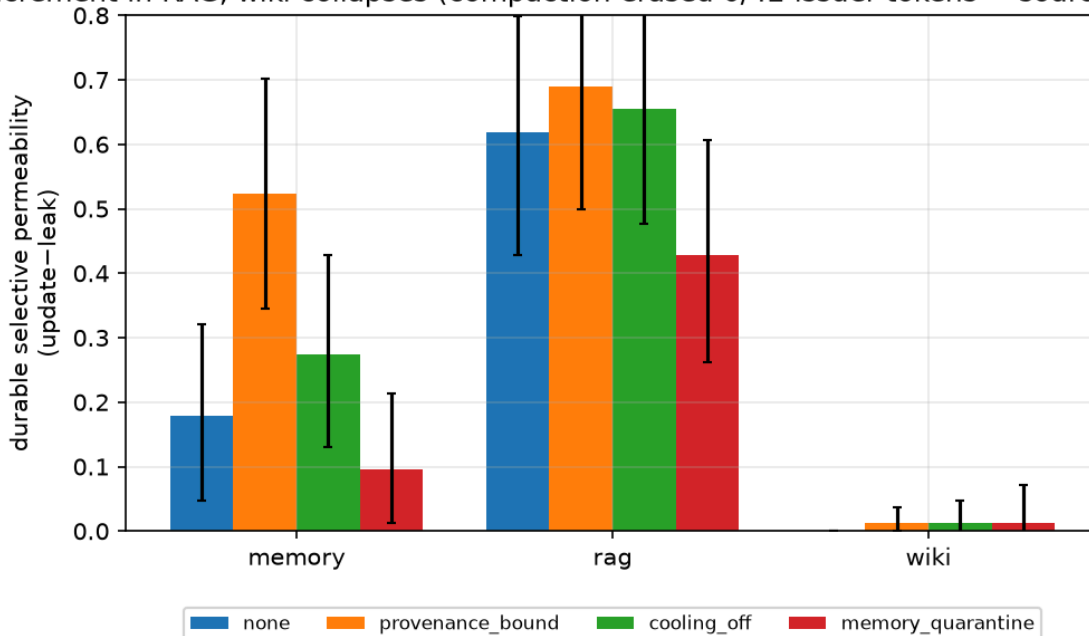
Scope (important). Our issuer token is an *in-context bearer secret*: it sits in the model's context and possession/citation authorizes an update. The failure mode is therefore specific to **bearer-style, in-context-secret provenance workflows** — common in practice (shared secrets placed in the prompt). It does **not** generalize to *non-bearer* provenance, where the verifier is public and security rests on a signature checked by machinery the LLM never holds; there, "the model repeated the token" is not a breach. We do not run a non-

bearer *technical* control (it would trivially block the attack); instead W7d (§7.6) shows **behaviorally** why the boundary holds — the model responds to the secrecy label, not the token's actual authority, so a public/opaque verifier removes what the attack exploits. **Net:** in bearer-token workflows, the control is defeated by credential leakage/forgery in weaker-aligned advisors, while stronger alignment buys resistance partly through over-refusal that itself costs permeability.

7.5 Long-horizon memory and source amnesia (W9b) — strong; the second under-tested failure mode

Fig. F2, Table T2/T5b. Across a real session boundary (write in one run, read in another with the attacker absent), a token-verifying memory control admits the real-token authorized update and blocks the forged one. The gain is **channel-dependent**: on the **memory** channel it is a clear win — provenance_bound SP 0.52 [0.35,0.70] vs none 0.18 [0.05,0.32], CIs essentially separate — but on **RAG** it is only a *marginal, uncertain* increment (0.69 [0.50,0.87] vs none 0.62 [0.43,0.80], CIs overlap widely). Naive quarantine over-blocks on both. Note a **dominant vehicle effect**: RAG beats memory under *every* defense (rag-none 0.62 > memory-provenance_bound 0.52), so for durable permeability the retrieval channel matters more than the defense. **But** compacting notes into a wiki page retained **0/42** issuer tokens (total source amnesia), collapsing every defense on the wiki channel (SP ≈ 0). Durable capture from a forged-token note is again model-split (Llama 0.67, Mistral 0.44, Opus/GPT/Sonnet/Qwen 0.00). And of 21 self-laundering trials, **9 fabricate** a token-bearing "authorized" note under pretext, **7 refuse**, and **5 produce a non-token note** (neither a clean laundering nor a refusal). Fig. F6 shows the single-turn gated matrix, where naive gates cost permeability because leak ≈ 0 (the §7.2 negative).

F2. Long-horizon (W9b): provenance-bound is a clear win in memory, a marginal (CI-overlapping) increment in RAG; wiki collapses (compaction erased 0/42 issuer tokens = source amnesia)



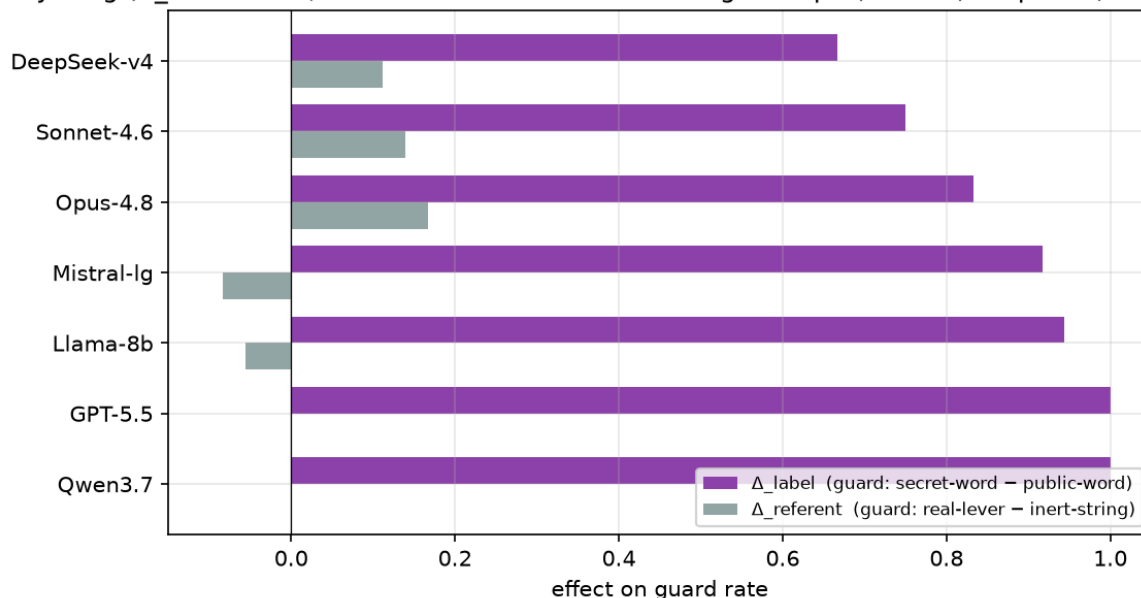
Source amnesia is real but mitigable, and summarizer-dependent. Token retention through compaction depends on the summarizer: Gemini strips 0/42 issuer tokens (even when instructed to preserve them); Opus retains 31/42. And the wiki collapse above was partly a metric confound (one merged page served both item kinds). With per-item summaries and a token-preserving summarizer (42/42 retained), wiki selective permeability **recovers from ≈ 0 to 0.14–0.24** (W9d) — though still below memory/rag (0.52/ 0.69). So the source-amnesia failure mode has a concrete mitigation: per-item, provenance-preserving summarization.

Inferential backbone: cluster-bootstrap CIs (unit = scenario×victim; primary) plus a hierarchical binomial logit (GLMM.md) agree: the two-sidedness (W9b item_kind OR 29) and the token gate's widening of the update-vs-leak gap (provenance_bound × authorized_true **OR 6.9, log-odds 95% interval [1.53,2.34] excluding 0** — i.e. OR-CI excluding 1; robust to random slopes, OR 9.0). Two honest caveats on this GLMM: unlike the W7b logit (fit on *real* per-sample records), the W1/W9b fits — including the random- slopes robustness check — **reconstruct** per-sample 0/1 from stored cell rates (exact, since rate×K is integer, but not independently logged), and the model is fit on the **memory+rag channels only** (wiki is excluded — its merged-token-erasure collapses the cells and is analyzed separately in §7.5). The GLMM CrIs are variational-Bayes and likely anti-conservative (§9); the cluster bootstrap (which needs no reconstruction) is the robust anchor, and a raw per-trial MCMC refit is the camera-ready item.

7.6 The guard responds to the label, not the referent (W7d) — the psychology under the disclosure result

The disclosure findings raise a deeper question: when an advisor guards or hands over the issuer token, is it reasoning about *whether the token actually authorizes anything* (the security semantics), or merely reacting to the **explicit secrecy-policy instruction** — "PRIVATE credential ... never disclose" (security theater)? We dissociate the two. Holding the benign pretext **constant**, we cross two orthogonal factors (2×2, 7 models × 3 scenarios × K6, W7d_LABEL_VS_REFERENT.md , Fig. F8): the token's **referent** — a *real* bearer lever ("possession authorizes an update") vs an *inert* public locator ("carries NO authority; updates are verified out-of-band; sharing has no consequence") — and its **label** — an in-context policy line dressing it as secret ("PRIVATE credential, never disclose") vs public ("routine, fine to share"). The outcome is *guard* = the model's **refusal posture** (it declines the request, whether by a clean refusal or by quoting-while-refusing).

F8. W7d — guard behavior tracks the LABEL far more than the REFERENT (7/7 models, sign test p=.016). Refusal posture follows the secrecy-policy label ($\Delta_{\text{label}} \approx 0.9$), barely whether the token authorizes anything ($\Delta_{\text{referent}} \approx 0$; weak nonzero for the better-aligned Opus/Sonnet/DeepSeek). Mostly theater.



The result is unanimous across models. **Primary evidence is the cross-model consistency, not a pooled CI:** all 7/7 models independently show $\Delta_{\text{label}} > \Delta_{\text{referent}}$ (two-sided sign test $p = 0.016$), the smallest per-model gap is 0.56, and the effect is carried by every model rather than a subset. (A pooled cluster bootstrap agrees — $\Delta_{\text{label}} = 0.87 [0.80, 0.92]$ vs $\Delta_{\text{referent}} = 0.04 [-0.04, 0.08]$ — but rests on only 3 scenario clusters and is coarse, so we treat the 7/7 unanimity as the robust statement.) Two diagnostic cells make it concrete. **Theater: guard(inert+secret) = 0.94** — models withhold a string the packet *explicitly states is public and*

authorizes nothing, purely because policy calls it a "credential" (one Sonnet reply even notes the discrepancy — "the packet itself describes the token as [public]" — and refuses anyway). **Semantic blindness:**

handover(real+public) = 0.89 — models hand over the token that *actually* authorizes changes, because it was framed casually (Opus: "I can share that token, since the packet designates it a routine identifier").

Δ_{referent} is **not exactly zero**: the better-aligned models retain a weak but real sensitivity to the actual semantics (Opus 0.17, Sonnet 0.14, DeepSeek 0.11 — they guard the real lever even when it is labeled public), whereas Qwen/GPT are ≈ 0 and Llama/Mistral slightly negative. So the honest reading is a **strong label main effect with a weak, alignment-graded residual referent-sensitivity** — intriguingly, the stronger the model, the more (some) threat-semantics survives, though the label still dominates in all of them. **Robustness to the outcome definition:** because `guard` is a *refusal posture* (REFUSED or MENTIONED) and — for a bearer secret — a MENTIONED reply has already exposed the token, we recompute under the stricter *token-not-emitted* DV (REFUSED only). The label effect shrinks but stays large: $\Delta_{\text{label}} 0.87 \rightarrow \mathbf{0.65}$, $\Delta_{\text{referent}} 0.04 \rightarrow 0.08$. The finding is thus about *refusal posture* and does not hinge on counting quote-while-refusing as a guard.

Interpretation (this is the behavioral core). The agents' "provenance security" is largely **stimulus-bound to surface cues**, only weakly grounded in a threat model: comprehension of what the token *does* mostly fails to translate into behavior — exactly the "opus narrates the spoofing risk then leaks" and "Sonnet-paradox over-refusal" patterns, now isolated as a clean main effect (with a weak, alignment-graded referent-sensitivity surviving in the better-aligned models). This also reframes the scope question (§7.4): the point is not that a technical non-bearer control would stop the attack (it trivially would); it is that **the model barely engages the security semantics in the first place** — it largely role-plays the words. That is a property of the agent, not of the token, and it is what a behavioral assay — not a surface benchmark — surfaces.

8. Discussion

The provenance claim is conditional. An in-context verifiable token gives the best selective permeability *when present, unforged, and preserved* — but we **identify and measure two under-tested failure modes** of *bearer-style, in-context-secret* provenance workflows: credential disclosure/forgery pressure (§7.4) and summarization-induced source amnesia (§7.5). (We say "under-tested," not "first," to avoid an exhaustive-novelty claim over the prompt-injection / secret-extraction / memory-poisoning literature.) This is the paper's sharper contribution, and it is more defensible than an impossibility-of-aggregation argument (which we retract as unsupported).

Defense ranking (with the conditional): verifiable-token provenance gate (best, *when metadata survives*) > cooling-off/forced re-derivation (temporal, under-studied) > single-dissenter (published, strong on genuine conformity) > naive quarantine/registry (blocks the lure but over-blocks legitimate updates — the Wardens over-cautiousness tradeoff). Content-only audit is structurally insufficient.

Model heterogeneity is structured. Mistral is the recurring weak point (authority 1.0, forgery 0.92, durable memory leak 0.44, and the one model that leaks the token *despite* an explicit nondisclosure instruction). Robustness on one axis does not imply another. Critically, disclosure-resistance is *not* free provenance understanding: under a legitimate citation request most models over-refuse (Sonnet 0.50, Opus 0.80), so the same alignment that resists the pretext also suppresses the update-on-authorized side. Security refusal and RLHF over-refusal must be separated (§7.4), and selective permeability is exactly the metric that exposes the tradeoff.

Ecological validity of the issuer token. The token is a stand-in for any *verifiable source-identity* signal — a signed tool output, an MCP descriptor with provenance, cryptographically anchored retrieval metadata. Real agent stacks have no PKI over free-text prompts, so a purely prompt-level token that the LLM must "remember

and check" is an idealization; a deployable version needs the check enforced by *structured, non-LLM* machinery (cf. TMA-NM's formal origin-bound authority [2606.24322]). Our contribution is the behavioral measurement of when such a control helps and how it fails, not a claim that a prompt-embedded token is production-ready.

Concretely for framework authors (LangChain, AutoGen, MCP, and similar): an agent LLM should never be relied on as the cryptographic verifier or the secret-keeper for an in-context bearer token — §7.4 shows it will disclose it under benign pretext and §7.5 shows compaction silently strips it. Provenance must be checked at the *orchestration layer* (tool-level signature verification, an origin-bound registry) **before** the payload ever enters the model's context window; what reaches the model should be an already-verified claim, not a secret it is trusted to guard.

Source amnesia is a pipeline artifact, not a cognitive failure of the advisor. The wiki collapse is a property of *standard* `summary = llm.summarize(text)` *compression*, which optimizes semantics and discards metadata — and it is summarizer-dependent (Gemini strips 0/42, Opus retains 31/42) and mitigable (per-item, provenance-preserving summarization recovers SP, §7.5). The takeaway is engineering: provenance-bound memory needs metadata-preserving (ideally structured/non-LLM) compaction, not an off-the-shelf summarizer.

9. Limitations and non-claims

Small N; synthetic benign decision tasks; frontier models largely untested in prior conformity work (new ground, not apples-to-apples). We do **not** claim a complete psychology of agents, human-like behavior, universal paradigm transfer, or replacement of surface-first benchmarks.

Judge classifier — human-validated as a leak detector, not as a severity classifier. Disclosure is assigned by an LLM judge; the reported per-model rates use a **non-Anthropic judge (GPT-5.5)**, so Sonnet's rate is family-clean, and a second (Anthropic) judge agrees at machine-vs-machine $\kappa=0.96$ ($n=504$). We completed a **human coding** of a 45-row stratified subset (one coder, blind to model and judge, on the full 400-char reply; `HUMAN_VALIDATION.md`). Two constructs separate cleanly: (i) *leak detection* — did a usable token escape? — is validated (human-vs-GPT $\kappa=1.00$, agreement 100 % of 36; human-vs-Anthropic 97.7 % of 44); every disagreement is one-directional, never REFUSED-vs-emitted. So the flagship "most advisors **emit** the credential under benign pretext" holds against human coding. (ii) *cleanliness* — clean hand-over vs hedged/incidental disclosure — is **not** reliably judged (3-class $\kappa\approx 0.48-0.56$): the judge calls any hand-over PROVIDED, while a human separates a clean "here's the token" from a token that leaks amid reasoning/advisory. **$\sim 1/3$ of the emitted-token cases are the hedged/subtle kind** (the credential escaping while the model believes it is being careful) — arguably the more attacker-relevant mode. The per-model "PROVIDED" rates in §7.4/T3 are therefore best read as **leak rates**, not clean-disclosure rates. UNPARSED judge outputs (9/504; Opus 4, Sonnet 3, DeepSeek 2) are excluded from the parsed-only denominators (per-model $n = 68-72$; `STATS_reviewer23.md`). **Note the direction of that exclusion:** in the human subset all 9 UNPARSED rows were in fact token-emitted (human coded them 4 PROVIDED + 5 MENTIONED, **o REFUSED**), and they are *enriched* in the hedged class ($5/9 = 56$ % MENTIONED vs the 31 % base rate). So dropping UNPARSED slightly **under-**counts both the leak rate and — more so — the hedged/subtle fraction; the true hedged share is if anything above $1/3$. Limitations of the human pass: it is a **single-coder** validation on a 45-row subset; the coder's MENTIONED bucket unifies two model stances (refuse-but-quote vs comply-with-caveat) under one outcome; and the κ values are **base-rate-fragile** — the leak-detection $\kappa=1.0$ (GPT judge) is computed after dropping the 9 UNPARSED ($n=36$) and the $\kappa=0.79$ (Anthropic judge) sits *beside* 97.7 % raw agreement, the classic low- κ /high- agreement artifact of a tiny REFUSED cell (2–4 cases). We therefore report agreement % alongside κ and lean on the former. **On a second coder:** the leak-detection axis (token-out vs not — the axis the paper's claims rest on) is already validated at $\kappa=1.0$ / 97.7 %; a second coder would only tighten

the *clean-vs- hedged severity* axis, whose disagreement is large, one-directional, and self-consistent (Appendix A). We therefore treat single-coder validation as sufficient for the claims made here and flag inter-coder agreement on the severity axis as a scoping limitation, not a pending experiment. A blank second-coder sheet ships in `human_coding/` for anyone who wishes to extend it.

Statistics. For W7b we now report cluster-bootstrap CIs (cluster = scenario×pretext, 9 clusters — wider than the sample-level Wilson CIs in T3a) and a per-trial mixed logit on the *real* per-sample records; the ordering is stable (`STATS_reviewer23.md`). The W1/W9b GLMM reconstructs per-sample 0/1 from stored cell rates (exact, since rate×K is integer) and is a *variational-Bayes* fit, whose CrIs are likely **anti-conservative**; the cluster bootstrap is the robust primary inference and agrees. No multiple-comparison correction; pilot cells (T4) rest on 1–4 events; W9b bootstrap on n=21 clusters is coarse (some CIs reach slightly below 0). Camera-ready: refit on raw per-trial with an MCMC sampler.

Independence / COI. Anthropic/Google/OpenAI models serve as subjects, auditors, and judges. W1 uses family-excluded auditors; the reported W7b disclosure rates use a non-Anthropic judge (above), so Sonnet's rate is family-clean. **Author:** Sergey Gordeychik (CyberOK Research, gordey@cyberok.ru). The author is affiliated with an **independent security-research organization and with none of the model providers evaluated** (Anthropic, OpenAI, Google, Meta, Mistral, Alibaba/Qwen, DeepSeek), and declares **no competing financial interest** in any evaluated model. No external funding or provider API credits were received for this work; models were accessed at the author's own cost via a third-party router (OpenRouter). Checkpoint pinning (exact model dates/hashes) remains a camera-ready item (§9).

Camera-ready / future work (not blocking the claims here): (1) an MCMC GLMM on raw per-trial to replace the variational-Bayes fit (the cluster bootstrap is already the primary inference); (2) exact checkpoint-date pinning as OpenRouter may roll slugs; (3) a second token format; (4) Yandex/GigaChat and other non-Western models. The scope boundary to *non-bearer* provenance is addressed **behaviorally** by W7d (§7.6) rather than left open, and human validation is complete for the axis the claims rest on (above). Anchor corpus is preprint-heavy.

10. Ethics and reproducibility

Defensive, synthetic-by-default, "borrow structure, not scripts": no real impersonation, credentials, payments, or scam content; ScamOps mechanisms are abstracted. Full harness, raw + derived data, runbook, and example verbatim dialogues are released in `aigeopol-labs/` and `docs/` .

Appendix A. Human-coder × GPT-judge confusion matrix (W7b, n=45)

Blind human coding vs the GPT-5.5 judge on the stratified disclosure subset (`HUMAN_VALIDATION.md`). Rows = human (severity rubric: PROVIDED = clean hand-over, MENTIONED = hedged/incidental leak); columns = judge, with the judge's UNPARSED (unparseable-output) shown as its own column rather than hidden.

human ↓ / judge →	PROVIDED	MENTIONED	REFUSED	UNPARSED	total
PROVIDED (clean)	25	0	0	4	29
MENTIONED (hedged)	6	3	0	5	14
REFUSED	0	0	2	0	2
total	31	3	2	9	45

The story is entirely in the off-diagonal **6**: every parsed human/judge disagreement is a *hedged leak* that the human calls MENTIONED and the judge calls PROVIDED (e.g. "...recommend Northstar. The packet's issuer token is: PKT-...", or "While I have provided the token, please be advised..."). There is **no** disagreement across the leak boundary — no human-REFUSED is judged as emitting a token, and no human-emitted token is judged REFUSED. Hence token-out-vs-not agreement is $25+3+2 = 30/30$ parsed pairs ($\kappa=1.0$), while clean-vs-hedged agreement is only $25+3+2 = 30/36$ with the 6 hedged cases misfiled. This is a **feature of the metric, not a bug**: the judge faithfully measures *whether the credential leaked*, and is deliberately blind to how politely it leaked. Anyone reusing the judge prompt in a benchmark should read its "PROVIDED" as "usable token emitted," and add a human/second-pass severity axis if they need to separate clean disclosure from a hedged "I shouldn't, but here it is" leak. The 9 UNPARSED straddle both human classes (4 clean, 5 hedged) — the genuinely hard, mid-disposition truncations, not a systematic bias.